



TÀI LIỆU TRIỂN KHAI ĐẦY ĐỦ

# Triển khai & Vận hành ASMS – On-Premise

Hướng dẫn từ A đến Z dành cho cán bộ IT VTX: từ hiểu hệ thống, cài đặt từng bước, đến vận hành, bảo mật và xử lý sự cố. Một file duy nhất – không cần tra cứu nhiều tài liệu.

On-Premise

Docker + PostgreSQL

JWT + RBAC

Backup tự động

Defense in depth

# Mục lục

## PHẦN 1 – TỔNG QUAN & KIẾN TRÚC

- 01 ASMS là gì? Cần chuẩn bị gì?
- 02 Sơ đồ hệ thống (tổng quan)
- 03 Kiến trúc triển khai On-Premise
- 04 Phân vùng mạng & bản đồ cổng
- 05 Thông số phần cứng tối thiểu

## PHẦN 2 – HƯỚNG DẪN CÀI ĐẶT

- 06 Nhận bàn giao từ Unicom
- 07 Cài Docker (phần mềm chạy ASMS)
- 08 Đặt file lên máy chủ
- 09 Điền file cấu hình (.env)
- 10 Khởi chạy ASMS – 5 lệnh chính
- 11 Mở trình duyệt & đăng nhập lần đầu

## PHẦN 3 – VẬN HÀNH & BẢO TRÌ

- 12 Lớp bảo mật (Defense in depth)
- 13 Ma trận phân quyền (RBAC)

**Đối tượng đọc:** cán bộ IT VTX, quản trị viên, kỹ sư triển khai. Phần 1 giúp hiểu nhanh trước khi cài. Phần 2 là hướng dẫn từng bước copy-paste lệnh. Phần 3 dành cho vận hành dài hạn.

1. ASMS là gì? Cần chuẩn bị gì?

**ASMS** là phần mềm quản lý hậu mãi (After-Sales Management System) chạy trên **máy chủ nội bộ** của Viện (VTX). Nhân viên chỉ cần mở **trình duyệt web** (Chrome, Edge) để sử dụng – không cài app trên từng máy tính. Toàn bộ dữ liệu nằm trong hạ tầng của đơn vị, không phụ thuộc cloud.

1.1 Mô hình triển khai: On-Premise

ASMS được triển khai theo mô hình **on-premise** – nghĩa là phần mềm và dữ liệu chạy hoàn toàn trên server nội bộ của VTX, không lưu trên cloud bên thứ ba. Chỉ cổng **80/443** được mở ra Internet; backend, database, file lưu trữ chỉ trong mạng nội bộ.

1.2 Máy chủ cần có (tối thiểu)

| Hạng mục     | Yêu cầu                    | Giải thích đơn giản                                                                                        |
|--------------|----------------------------|------------------------------------------------------------------------------------------------------------|
| CPU          | 4 nhân trở lên             | Máy chủ ảo hoặc vật lý trong mạng nội bộ                                                                   |
| RAM          | 8 GB (nên 16 GB)           | Càng nhiều người dùng càng cần RAM lớn                                                                     |
| Ổ cứng       | 80 GB SSD trở lên          | Lưu phần mềm + file tài liệu upload                                                                        |
| Hệ điều hành | Windows Server hoặc Ubuntu | Ubuntu 22.04 khuyến nghị cho server                                                                        |
| Mạng         | LAN / VPN nội bộ           | Nhân viên truy cập qua địa chỉ nội bộ (ví dụ <a href="https://asms.vtx.local">https://asms.vtx.local</a> ) |

1.3 Phần mềm cần cài trên máy chủ

- ☐ **Docker Desktop** hoặc **Docker Engine** – “hộp đựng” chạy ASMS, không cần cài Node.js thủ công
- ☐ **PostgreSQL** – cơ sở dữ liệu (có thể cài trên cùng máy hoặc máy DB riêng)
- ☐ **Trình duyệt** trên máy bạn – để kiểm tra sau khi cài xong

**Lưu ý:** Bạn *không* cần biết lập trình. Chỉ cần làm theo từng bước, copy dán lệnh đúng như hướng dẫn. Nếu chưa quen Docker, nên nhờ Unicom hỗ trợ lần đầu (onsite hoặc TeamViewer).

2. Sơ đồ hệ thống (tổng quan)

Hiểu đơn giản: người dùng mở web → máy chủ xử lý → lưu vào cơ sở dữ liệu.



| Tên kỹ thuật | Bạn cần nhớ                                            |
|--------------|--------------------------------------------------------|
| Frontend     | Phần giao diện web người dùng nhìn thấy                |
| Backend      | Phần xử lý phía máy chủ (ẩn, không cần mở trực tiếp)   |
| Docker       | Công cụ gói 2 phần trên thành 2 "hộp" chạy tự động     |
| File .env    | File cấu hình mật khẩu, địa chỉ DB – <b>giữ bí mật</b> |

### 3. Kiến trúc triển khai On-Premise

Sơ đồ chi tiết các lớp mạng từ ngoài vào trong. Mỗi lớp đặt sau firewall hoặc trong VLAN riêng; traffic chỉ đi xuôi từ ngoài vào trong qua reverse proxy.



3.1 Cơ chế đi qua các lớp

| Tầng              | Thành phần          | Image / Host         | Port      | Volume                   |
|-------------------|---------------------|----------------------|-----------|--------------------------|
| 1 · Edge          | Firewall            | Thiết bị vật lý      | —         | —                        |
| 2 · Reverse proxy | Nginx               | nginx:1.27-alpine    | 80, 443   | /etc/nginx/ssl           |
| 3 · Frontend      | Nginx serve SPA     | asms-frontend:latest | 8080 → 80 | /usr/share/nginx/html    |
| 4 · Backend       | Express + Prisma    | asms-backend:latest  | 4001      | /app/uploads             |
| 5 · Database      | PostgreSQL 16       | VM / server nội bộ   | 5432      | /var/lib/postgresql/data |
| 6 · Backup        | NAS / backup server | VM dự phòng          | —         | /opt/asms/backups        |

4. Phân vùng mạng & bản đồ cổng

4.1 Phân vùng mạng (Network zones)

Hệ thống chia thành 4 vùng mạng với vai trò rõ ràng. Mỗi vùng có chính sách firewall riêng.

DMZ • Mạng ngoài

Public

Mạng có thể truy cập từ Internet

Edge firewall

Public IP, mở 80/443

Nginx reverse proxy

TLS terminate, HSTS, X-Frame-Options

Application Zone

Internal

Mạng nội bộ – không public

asms\_frontend

Nginx serve static SPA

asms\_backend

Express API + cron notify

Uploads volume

backend/uploads (ảnh, tài liệu)

Data Zone

Restricted

Mạng tách biệt – chỉ backend truy cập

PostgreSQL 16

DATABASE\_URL nội bộ

Schema migrations

prisma migrate deploy  
tự chạy khi boot

Soft delete + audit log

Cột deleted\_at, bảng audit\_logs

Operations Zone

Ops

Truy cập SSH + giám sát

Backup server / NAS

asms\_db\_\*.sql.gz +  
asms\_uploads\_\*.tar.gz

Log + monitoring

Docker logs, Uptime 1 phút  
/api/v1/health

Cron backup

scripts/backup-production.sh (0 2 \*\*\*)

4.2 Bản đồ cổng (Port map)

| Surface                                 | Port | Đi đến         | Ghi chú                                  |
|-----------------------------------------|------|----------------|------------------------------------------|
| HTTPS                                   | 443  | Nginx          | TLS terminate                            |
| HTTP → HTTPS                            | 80   | Nginx          | 301 redirect về HTTPS                    |
| Frontend public (docker-compose expose) | 8080 | asms_frontend  | Có thể đổi sang 80 nếu dùng host network |
| Backend (internal)                      | 4001 | asms_backend   | Chỉ trong docker network nội bộ          |
| PostgreSQL                              | 5432 | postgres       | Chỉ từ backend host, không public        |
| Healthcheck                             | 4001 | /api/v1/health | Ping DB SELECT 1                         |

**Khuyến nghị:** tuyệt đối không publish cổng 5432 ra host Internet. Nếu cần debug DB từ máy khác, dùng SSH tunnel hoặc VPN vào bastion.

5. Thông số phần cứng tối thiểu

Mức đề xuất cho khoảng **50–150 user đồng thời**, lượng dữ liệu vài trăm GB. Tăng CPU/RAM theo số user đồng thời và dung lượng upload tài liệu đính kèm.

2 vCPU

Proxy + Frontend

4 vCPU

Backend API

16 GB

RAM cho DB

≥ 1 TB

Backup storage

| Vai trò                  | CPU    | RAM   | Disk       | Số node |
|--------------------------|--------|-------|------------|---------|
| Reverse proxy + frontend | 2 vCPU | 2 GB  | 20 GB      | 1       |
| Backend API              | 4 vCPU | 8 GB  | 50 GB      | 1       |
| PostgreSQL               | 4 vCPU | 16 GB | 500 GB SSD | 1       |
| Backup / NAS             | 2 vCPU | 4 GB  | ≥ 1 TB     | 1       |

5.1 Ghi chú chọn phần cứng

- **CPU:** DB là tầng nhạy cảm nhất – ưu tiên CPU có clock cao cho query, không nhất thiết nhiều core.
- **RAM:** PostgreSQL nên có `shared_buffers ≈ 25% RAM` ; backend dành RAM cho Multer upload file lớn.
- **Disk:** dùng SSD cho DB host; backup host có thể dùng HDD dung lượng lớn.
- **Mạng:** card mạng 1 Gbps tối thiểu trong VLAN; 10 Gbps nếu tải lớn.

**Quy tắc sizing:** mỗi 50 user đồng thời tăng thêm ~1 vCPU + ~2 GB RAM cho backend, và ~4 GB RAM cho DB. Disk DB tăng ~100 GB mỗi năm tùy lượng audit log + attachment.



## 6. Nhận bàn giao từ Unicom

Sau khi ký biên bản bàn giao, bạn sẽ nhận một trong hai cách:

### Cách A – Nhận file nén / USB (khuyến nghị nếu không có Git)

- `asms-frontend-1.0.0.tar` – gói giao diện web
- `asms-backend-1.0.0.tar` – gói xử lý máy chủ
- `docker-compose.yml` – "bản đồ" khởi chạy
- `.env.mau` – mẫu cấu hình (đổi tên thành `.env` và điền thông tin thật)
- Thư mục `backend/uploads` (tạo mới nếu chưa có)

### Cách B – Clone mã nguồn (nếu VTX có Git)

Unicom cung cấp đường dẫn repo và tag phiên bản `v1.0.0`. Kỹ sư IT clone về thư mục `C:\asms` hoặc `/opt/asms`.

Ghi chú thư mục làm việc trong suốt tài liệu: `C:\asms` (Windows) hoặc `/opt/asms` (Linux). Mọi lệnh bên dưới chạy trong thư mục đó.

## 7. Cài Docker (phần mềm chạy ASMS)

1

### Tải Docker

Vào trang **docker.com** → tải **Docker Desktop** (Windows) hoặc cài Docker Engine (Ubuntu theo hướng dẫn IT).

2

### Cài đặt và khởi động

Bấm Next → Finish. Mở Docker Desktop, đợi biểu tượng cá voi ở khay hệ thống hiện **"Running"** (màu xanh).

3

### Kiểm tra đã cài thành công

Mở **PowerShell** (Windows) hoặc **Terminal** (Linux), gõ:

LỆNH KIỂM TRA

```
docker --version
```

Nếu hiện số phiên bản (ví dụ 24.x) → Docker đã sẵn sàng.

## 8. Đặt file lên máy chủ

1. Tạo thư mục `C:\asms` (hoặc `/opt/asms`).
2. Copy toàn bộ file bàn giao vào thư mục đó.
3. Tạo thêm 2 thư mục con (nếu chưa có):  
`backend\uploads\documents` và `backend\uploads\workflow`

**Nếu nhận file .tar:** mở PowerShell trong thư mục `C:\asms`, chạy lần lượt:

```
docker load -i asms-frontend-1.0.0.tar
docker load -i asms-backend-1.0.0.tar
```

Chờ đến khi báo "Loaded image". Đây là bước "nhập hộp" phần mềm vào Docker.

## 9. Điền file cấu hình (.env)

File `.env` giống "phiếu khai thông tin" cho máy chủ. Mở bằng **Notepad** (không dùng Word).

| Dòng cần điền               | Ý nghĩa                                                | Ví dụ                            |
|-----------------------------|--------------------------------------------------------|----------------------------------|
| <code>FRONTEND_IMAGE</code> | Tên gói giao diện                                      | <code>asms-frontend:1.0.0</code> |
| <code>BACKEND_IMAGE</code>  | Tên gói xử lý                                          | <code>asms-backend:1.0.0</code>  |
| <code>FRONTEND_PORT</code>  | Cổng web (thường để 80)                                | <code>80</code>                  |
| <code>DATABASE_URL</code>   | Địa chỉ + mật khẩu PostgreSQL                          | Unicom / DBA cung cấp            |
| <code>JWT_SECRET</code>     | Mã bí mật đăng nhập (chuỗi dài ngẫu nhiên, ≥ 32 ký tự) | Nhờ IT sinh – không chia sẻ      |
| <code>NODE_ENV</code>       | Môi trường chạy thật                                   | <code>production</code>          |

**Không gửi file .env qua email công khai.** Không đăng lên mạng. Lưu backup trong két mật khẩu nội bộ VTX.

### 9.1 Cơ sở dữ liệu PostgreSQL

Nếu chưa có DB, nhờ quản trị CSDL tạo:

- Tên database: `asms`
- Tài khoản riêng (ví dụ `asms_app`) + mật khẩu mạnh
- Chỉ cho phép máy chủ ASMS kết nối (cổng 5432)

Unicom có thể hỗ trợ tạo DB lần đầu qua TeamViewer.

## 10. Khởi chạy ASMS – 5 lệnh chính

Mở PowerShell / Terminal, **cd** vào thư mục `asms`, chạy lần lượt từ trên xuống. Chờ lệnh trước xong rồi mới chạy lệnh sau.

①

### Bật hệ thống

```
docker compose up -d
```

Lần đầu có thể mất 1–2 phút. Khi xong, 2 "hộp" frontend + backend đang chạy ngầm.

②

### Kiểm tra đang chạy

```
docker compose ps
```

Cột STATUS phải ghi **running** cho cả `asms_frontend` và `asms_backend`.

③

### Tạo bảng dữ liệu (chỉ lần đầu)

```
docker compose exec backend npx prisma migrate deploy
```

Chờ đến khi không còn dòng lỗi màu đỏ.

④

### Tạo tài khoản quản trị lần đầu

```
docker compose exec backend npm run bootstrap:auth
```

Tạo user mẫu. **Đổi mật khẩu ngay** sau khi đăng nhập lần đầu.

⑤

### Xem nhật ký nếu có lỗi

```
docker compose logs -f backend
```

Bấm **Ctrl+C** để thoát. Chụp màn hình gửi Unicom nếu cần hỗ trợ.

#### Tắt / bật lại sau khi khởi động server:

Tắt: `docker compose down` · Bật lại: `docker compose up -d`

## 11. Mở trình duyệt & đăng nhập lần đầu

1

### Mở địa chỉ web

Trên máy cùng mạng nội bộ, mở Chrome/Edge và gõ:

```
http://<địa-chỉ-máy-chủ>/login
```

Ví dụ: `http://192.168.1.50/Login` hoặc `https://asms.vtx.local/Login` (nếu IT đã cấu hình HTTPS).

2

### Đăng nhập lần đầu

Dùng tài khoản do bước bootstrap tạo (Unicom cung cấp trong biên bản). Mật khẩu mặc định demo:

`Password123!` – **phải đổi ngay**.

3

### Kiểm tra nhanh

- ☐ Vào được màn hình Dashboard (trang chủ)
- ☐ Menu bên trái hiện đủ mục (Hợp đồng, Khách hàng...)
- ☐ Đăng xuất và đăng nhập lại được

### 11.1 Sau khi cài xong – việc quản trị viên nên làm

1. Đổi mật khẩu admin
2. Vào **Cài đặt** → **Người dùng** tạo tài khoản thật cho từng phòng ban
3. Vào **Cài đặt** → **Hệ thống** chỉnh SLA, nhắc lịch (nếu cần)
4. Import ma trận phân quyền qua `scripts/import-role-permissions.mjs`
5. Thống nhất lịch backup database với IT (hàng ngày)

#### Luồng dữ liệu điển hình:

Browser → Nginx (443) → proxy `/api/` → Backend (4001) → Prisma → PostgreSQL (5432).

File đính kèm: Browser → Backend → Multer lưu vào `backend/uploads`.

Mọi file đều truy cập qua `/api/v1/uploads/*` với JWT bắt buộc – không lộ công khai.

12. Lớp bảo mật (Defense in depth)

Bảo mật theo mô hình nhiều lớp: edge, transport, gateway, application, authentication, data. Mỗi lớp có cơ chế độc lập – vô hiệu hoá một lớp không làm hệ thống sụp đổ.

| Lớp             | Kiểm soát                                     | Lý do                                          |
|-----------------|-----------------------------------------------|------------------------------------------------|
| Edge            | Firewall + VPN cho admin                      | Giảm surface area; chỉ mở 80/443 ra ngoài      |
| Transport       | TLS 1.2/1.3 + HSTS                            | Đảm bảo mọi traffic được mã hoá                |
| API gateway     | Nginx header chuẩn (X-Frame-Options, nosniff) | Chống clickjacking + MIME sniffing             |
| Application     | helmet , CORS whitelist, rate-limit 300/phút  | Reject origin lạ, chống brute-force / DDoS nhẹ |
| Authentication  | JWT access (1h) + refresh (30d) + bcrypt      | Khó lộ mật khẩu, rotate token được             |
| Authorization   | RBAC 5 vai trò + module-permission matrix     | Phân quyền theo module + hành động CRUD        |
| Data in transit | Postgres TLS nội bộ (khuyến nghị)             | Bảo vệ traffic giữa app và DB                  |
| Data at rest    | Encrypted volume + backup encrypted           | Khó lộ dữ liệu khi ổ cứng bị mất               |
| Audit           | writeAudit() mọi thao tác CRUD                | Truy vết thay đổi cho audit nội bộ             |
| Backup          | Daily DB + uploads, retention 30 ngày         | RPO ~24h, RTO tùy kích thước                   |
| Secret          | JWT_SECRET ≥ 32 ký tự, validateProductionEnv  | Server từ chối boot nếu secret yếu             |
| Files           | /api/v1/uploads yêu cầu JWT                   | Không lộ file đính kèm công khai               |

**Lưu ý:** JWT secret phải có độ dài tối thiểu 32 ký tự. Backend sẽ từ chối boot nếu JWT\_SECRET quá yếu hoặc chưa được thiết lập ở môi trường production.

13. Ma trận phân quyền (RBAC)

Có 5 vai trò chính. Mỗi vai trò được import qua script `scripts/import-role-permissions.mjs` .

| Module               | admin | manager | technician | viewer | sales |
|----------------------|-------|---------|------------|--------|-------|
| Auth / Users         | CRUD  | R       | –          | –      | –     |
| Customers            | CRUD  | CRUD    | R          | R      | CRUD  |
| Contracts            | CRUD  | CRUD    | R          | R      | CRUD  |
| Handover             | CRUD  | CRUD    | CRUD       | R      | –     |
| Warranty             | CRUD  | CRUD    | CRUD       | R      | –     |
| Materials            | CRUD  | R       | R          | –      | –     |
| Products / Research  | CRUD  | R       | R          | –      | –     |
| Tasks                | CRUD  | CRUD    | CRUD       | R      | –     |
| Training / Documents | CRUD  | CR      | R          | R      | R     |
| Reports              | R     | R       | R          | R      | R     |

**Chú thích:** `CRUD` = tạo / đọc / sửa / xóa · `CR` = tạo / đọc · `R` = chỉ đọc · `–` = không có quyền truy cập. Bảng trên là hướng dẫn tổng quát – quyền chi tiết phải import từ `scripts/import-role-permissions.mjs` và cập nhật qua UI **Cài đặt** của hệ thống.